

B U P T

密码工程

第1讲、绪论（1） 课程介绍、密码工程背景

授课教师：王晨宇

时间：2026年3月5日



目录

contents

B U P T



1

课程介绍

2

密码工程概述

3

重要密码法律

1

课程介绍



课程介绍



✓ 1.1 基本信息

✓ 1.2 课程目标

✓ 1.3 课程讨论

✓ 1.4 课程内容

✓ 1.5 参考书目

✓ 1.6 关于作业提交

✓ 1.7 本课程注意事项



课程介绍

1.1 基本信息

B U P T

授课教师：王晨宇

联系方式：

- 邮箱：wangchenyu@bupt.edu.cn
- 手机：18611098789（微信）

助教：刘萱

联系方式：

- 邮箱：xuanliu@bupt.edu.cn
- 手机：15898013609（微信）



26年春季密码工程群

请各学委添加一下助教微信，并给助教提交一下手机号码、邮箱、QQ等联系方式。

请大家扫描加入微信课程群，后续请同学们把选课的同学拉群里。



学以致用

- 通过课程的学习，使得学生对密码学在工程开发领域的实践有全面深入的了解，为将来在学习和工作（科学技术研究，产品/服务开发、售前或者售后服务等等）中应用奠定知识基础，积累工程实践类的经验。

科研与竞赛

- 结合科研思维训练，推荐课堂上有意思的系统软件参加相关的密码竞赛，参加竞赛获奖的同学期末成绩有大比重加分。



学过什么课程？

对密码学的认识？

你期望从课程中学到什么知识？

设计这门课的初衷：

□ 从理论到实践

□ 将学过的抽象的信息安全数学基础及密码学知识，通过本课程进行实践，从而深刻理解信息安全中最核心的技术之一在实际中的应用。

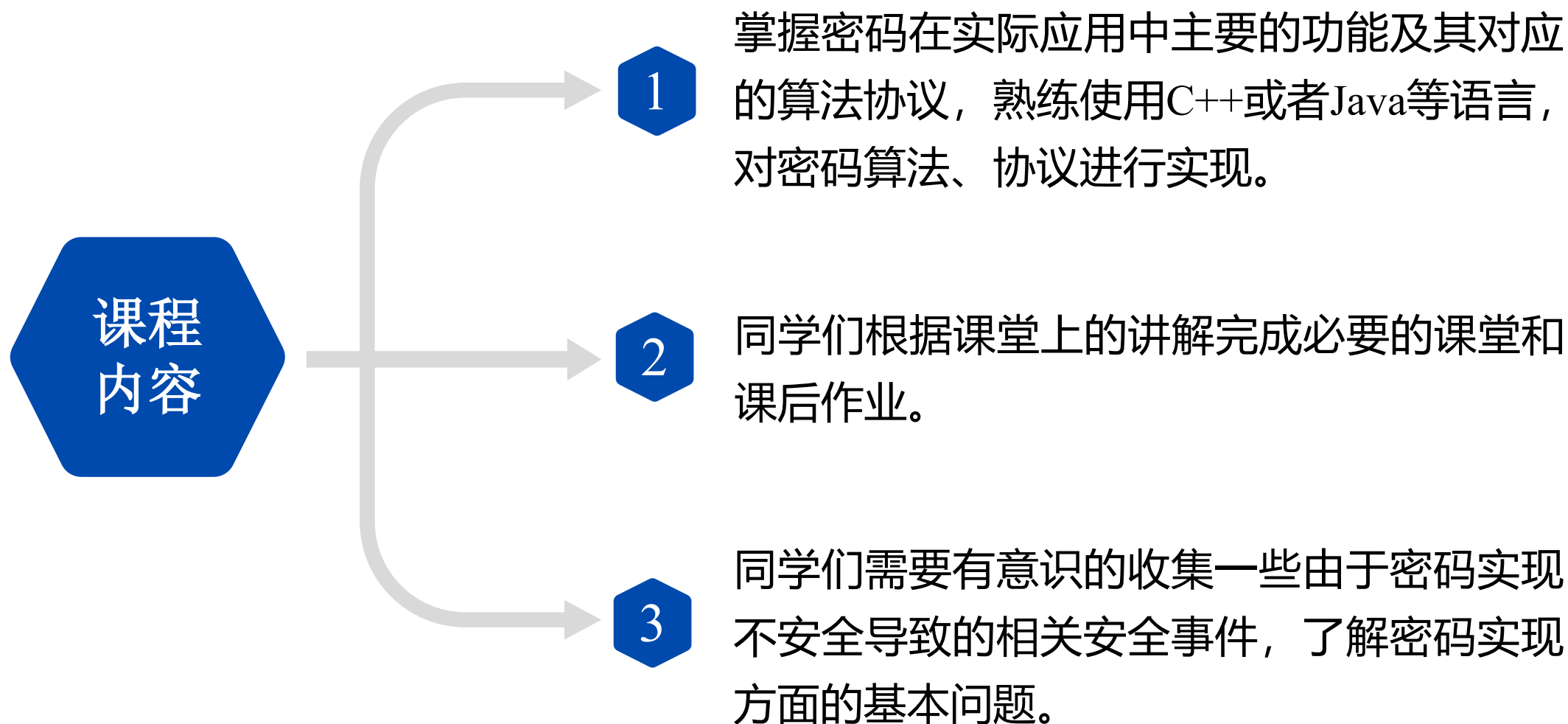
□ 结合实际生活

□ 通过动手，了解密码在生活中的作用、开放的时候面临的安全问题等。



同学们的想法很重要，本门课的目的是授之以渔，让同学们学习基本方法，发挥更大的主观能动性

- 主动提出想要实现的某项安全功能；
- 主动发现现有的方案的一些安全问题，并改进；
- 新兴技术的分享与实践；





信息安全竞赛

赛事通道

更多 >



已结束

第十九届全国大学生信息安全竞赛（创新实践能力赛）...

为深入践行总体国家安全观，积极落实国家网络空间安全人才战略，实现以赛促学、以赛促教、以赛促用，提质增效，推动网络空间安全人才培养和产学研用生态发展，中国信息安全测评中心和...

点击进入



已结束

第十八届全国大学生信息安全竞赛—作品赛

为选拔、推荐优秀网络空间安全专业人才，培养学生的创新意识与团队合作精神，提高学生的网络安全技术水平、创新实践与综合设计能力，推动我国高校网络空间安全专业建设与改革，由西安交...

点击进入

官网：<http://www.ciscn.cn/home>

密码技术竞赛

2025第十届全国密码技术竞赛决赛通知

2025第十届全国密码技术竞赛决赛将于2025年11月27日-29日在南开大学举行，现将决赛有关事宜通知如下：

一、组织架构

指导单位：国家密码管理局

主办单位：中国密码学会

承办单位：中国密码学会教育与科普工作委员会
南开大学

支持单位：华为技术有限公司
蚂蚁技术研究院

协办单位：天津灵创智恒软件技术有限公司
北京信息灾备技术产业联盟
北京国测中培教育科技有限公司

二、评审规则

组委会组织专家对决赛入围团队的作品分为9个评审专家组进行评审，主要考查决赛团队作品（软件、硬件或系统）的实际运行状况和团队综合协作能力。每个决赛团队答辩20分钟，其中讲解和演示环节15分钟，专家提问5分钟。

决赛要求参赛团队匿名答辩，在汇报PPT、演示软硬件系统、着装等环节不得出现单位名字、单位Logo等与单位相关的信息。

官网：<https://www.chinacodes.com.cn/>



- [1] Cryptography Engineering: Design Principles and Practical Applications Kohno
Tadayoshi, JOHN WILEY & SONS INC. 2010.03
- [2] 密码工程实践指南, Steve Burnett & Stephen Paine 著 (冯登国等译), 清华大学出版社 & The McGraw-Hill Companies. 2001.10
- [3] 应用密码学--协议算法与C源程序, Bruce Schneier 著 (吴世忠译), 机械工业出版社, 2000年1月。
- [4] Java加密与解密的艺术, 梁栋 著, 机械工业出版社
- [5] OpenSSL与网络信息安全—基础、结构和指令, 王志海 童新海 沈寒辉 编著, 清华大学出版社&北京交通大学出版社
- [6] 抽象语法记法ASN.1原理与应用, 鲍忠贵 刘贵全等编著, 国防工业出版社
- [7] 椭圆密码学导论, Darrel Hanerson等注, 电子工业出版社



成绩组成:

- 课后作业：调研资料学习 50%
- 期末提交密码工程相关领域的研究报告 50%
- 课后作业及期末研究报告
 - 课代表收齐后，统一发给助教。
- 文件名样例
 - 课后作业/期末论文-01-16-2015211001-张三-20190228.zip/doc/docx/rar，编号为01，16班，学号是2016211001，张三为姓名，最后是提交日期。
 - 每次作业都会提醒大家是第几次作业，这就是作业编号。



- 需要大家熟悉Java、C/C++、Python语言，本课程注重密码算法的实现、工具使用、以及软件工程的实现
- 为了更加好地方便大家掌握和学习，本课程内容融合了多本教材，教材的电子版材料之后会发到课程群里。
- 非常欢迎大家在学习本门课程的时候，多和我交流讨论，甚至可以以某一个大家感兴趣的密码功能为切入点，我们一起继续研究探讨，**形成论文、专利、参加密码相关的竞赛**
- 我的研究方向：密码协议、身份认证、天地一体化网络的安全、工业互联网安全，欢迎大家以本门课为切入点，加入实验室进行学习

2

密码工程概述



密码工程概述



✓ 2.1 什么是密码工程

✓ 2.6 专业偏执狂

✓ 2.2 追求性能带来的恶果

✓ 2.7 威胁模型

✓ 2.3 密码学的作用

✓ 2.8 密码系统不是唯一解决方案

✓ 2.4 木桶原理

✓ 2.9 棘手的密码系统

✓ 2.5 敌手设置

✓ 2.10 易于实现的密码系统



- 密码工程就是使用密码学知识解决生产、生活中的实际问题的方法和过程。根据课程安排，主要聚焦在国密算法工程实现相关的介绍。

问题总结

- 密码工程中的问题都有哪一些？

解决依据

- 相关的基础知识、理论要点。
- 相关的标准和专利知识。

解决方案

- 要求大家不仅仅是开发，更加需要大家有新的方案（需要大家不断思考学习）。



安全性是不可以妥协的，因此目前来讲这也是信息系统所不可以承受的；

□ 苏格兰福斯海湾大桥的故事。

□ 在1878年，Thomas Bouch建成了当时世界上最长的大桥，它横跨敦提的泰河海湾。

Bouch采用了铸铁和熟铁，使用了一种新的设计方法，这座大桥被认为是一个工程奇迹。建成不到两年，在1879年12月28日的夜里，大桥在一场暴风雪中倒塌了，当时正好有一列承载着75人的列车经过，列车上所有的人都遇难了。这在当时是一场巨大的工程灾难，所以，1882年当设计Forth海湾大桥的时候，设计者使用了更多的钢铁，这样做不仅使得大桥更安全，而且使公众看起来也觉的安全，并且是公认的铁路桥梁史上的里程碑之一。



- 在传统行业，大家普遍接受安全性高于性能，即愿意花费更多的成本和时间来保障工程系统的安全性。
- 但是在信息系统中，普遍更加追求性能，安全往往是外挂式的，滞后考虑。随着安全事件频繁出现，该问题得到了一定改善。



没有一个复杂的系统是安全的。复杂性是安全性的最大敌人。

- 一个有着20个选项的计算机程序，每一个选项都可以选中或者不选中，那么一共有100多万个不同的配置。
- 为了保证程序安全，就必须对100多万个可能的组合中的每一个进行测试，检测各个配置在任何可能的攻击下都是安全的，这项工作不可能完成。

安全和系统进化

- 安全面对的不仅仅是当下，也包括未来。



密码本身没有价值，必须作为一个系统的一部分，以起到相应的作用

- 日常生活中用到的锁也是一样的。
- 安全系统的绝大部分，比如其中的围墙和篱笆，其设计目的是为了把所有人都挡在外面。
- 密码系统扮演了锁的角色：它必须区分“好”的访问和“坏”的访问。
- 这比把所有人都拦在外面要困难得多。
- 因此，密码系统及其相关组件自然成为了任何安全系统的攻击点。



只有系统的最薄弱的点也没问题时，密码系统才能真正发挥作用

- 即使门、锁及锁链足够牢固，如果房子的窗户破了，小偷还是可以进来；
- 同样，如果攻击者发现系统的一个漏洞，例如缓冲区溢出（心脏流血攻击），则能够绕过密码系统，直接对漏洞进行攻击。

密码是安全系统的一个小部分，但却是关键的部分；部署密码功能极其重要。

- 密码中的身份认证、访问控制、加密等手段，至少提高了攻击者攻击系统的难度。



A security system is only as strong as its weakest link.

每个安全系统的安全性都取决于它最脆弱的环节。

□ 这是安全系统很难做到完全正确的最主要原因。

□ 为此：我们需要知晓最薄弱环节在哪里？是什么？

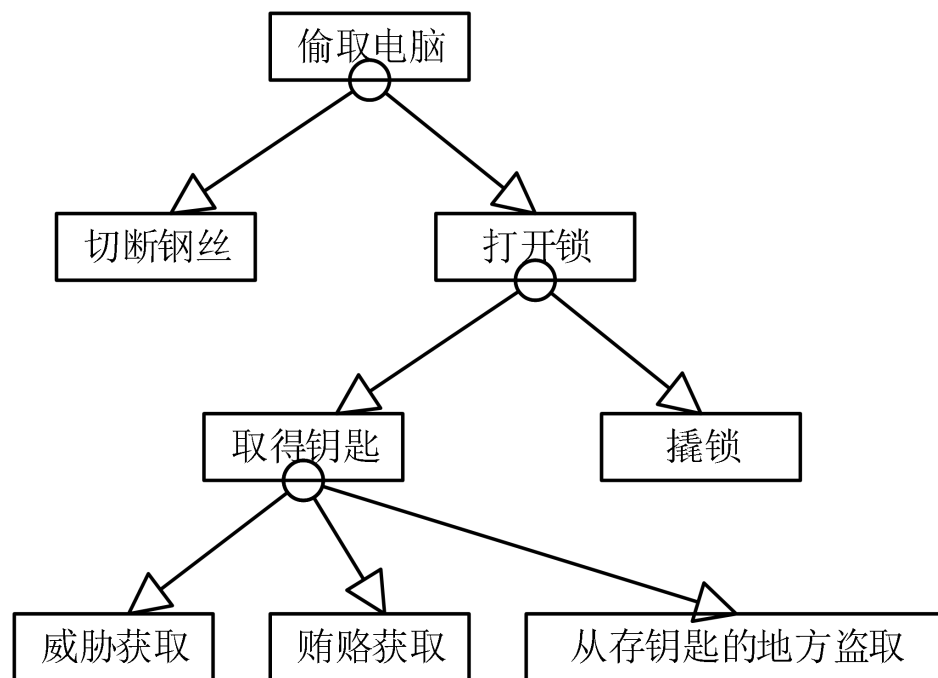
□ 屋顶开放的房子，门锁再棒又能怎么样呢？





攻击树是对已定义系统执行威胁和风险分析的方法

- 用树形结构来表示系统面临的攻击，其中根节点代表被攻击的目标，叶节点表示达成攻击目标的方法。



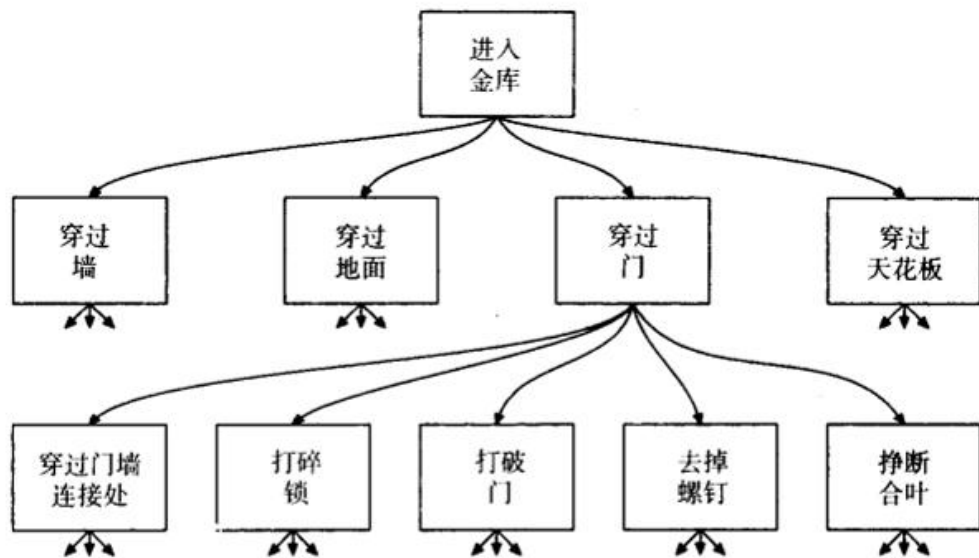


图 2.1 金库的攻击树

- 在实际场景中，对不同攻击能力的攻击者而言，其面临的系统最脆弱的环节不尽相同；哪个环节可能被攻击也取决于攻击者的目标
- 对多个环节进行强化能够使得系统具备纵深防御的性质：如果某个环节被攻破了，剩余环节还能保障安全



其他领域对破坏性因素的考虑往往是可预测的：

- 例如：塔科马海峡吊桥是位于美国华盛顿州塔科马的两条悬索桥。第一座塔科马海峡大桥，于1940年7月1日通车，四个月后戏剧性地被微风摧毁。
- 加固方案是针对微风来设计的，风是可以明确预测的，不会故意改变行为方式来破坏大桥
- 但是，对安全系统而言，**攻击者往往是“机智而怀有恶意”的风**，且攻击者的能力也在不断提升，因此，构建安全系统是一件复杂且有难度的事情；



敌手的设置是要引进一个非常苛刻的环境。

- 我们在抽象的意义下来谈论一个“攻击者”，但是不知道他是谁，他知道什么，他的目的是什么，他何时发起攻击，也不知道他所使用的方法是什么。
- 由于攻击会在我们设计系统很久以后发生，他可以有五年或者十多年的研究优势，并且可以使用我们所不知道的未来的技术。
- 而且，利用所有这些优势，他只需要找到系统中的一个脆弱点，而我们却要保护所有的区域。

尽管如此，我们的任务是构建一个能够抵抗所有攻击的系统。



安全系统需要你变得偏执，应该像一个恶意的攻击者一样去找你自己系统的漏洞。

- 假设你参与研发一个电子支付系统。
- 在这个系统中涉及到几个参与方：**客户、商家、客户的银行和商家的银行。**
- 对于每一个参与方，我们假定其他任何人都是要欺骗这个参与方的一个大阴谋团伙的成员。
- 如果你的密码系统在这样的妄想狂模型中可以幸存，那么它在现实世界中至少有生存下来的机会。



专业的偏执是这个行业的基本手段。

- 对于所面临的任何新系统，你所想到的第一件事情就是如何攻破它。
- 越快找到其弱点，你对这个新系统就了解得越快。
- 没有什么比下面这样的事情更糟糕了：在使用一个系统多年之后，有一个人走上前来说“但是，如果我以这种方式进行攻击该怎么办？”
- 我们实在不想经历那个措手不及的时刻。

偏执的专业思维对你自己的工作有广泛的好处：

- 偏执的安全专业思维会让你在设计、研究某一个系统的时候，考虑的更加全面，设计出更加安全的系统，比其他人考虑地更远一步。
- 对系统进行攻击，并不是对设计系统的人进行攻击，而是纯粹的技术交流与讨论。



- 每一个系统都可能受到攻击。就安全系统整体来说，就是规定某些人可以访问系统，而某些人则不能访问。
- 最终，总是要以某种方式体现出信任某些人，而这些人反过来也可以攻击系统。

要搞明白威胁是什么？

- 大多数公司使用防火墙来保护他们的LAN，但是多数真正有害的攻击都是由内部人员发起的，而防火墙一点儿也不能防止内部人员的攻击。
- 无论你的防火墙有多好，都不能防止一个怀有恶意的雇员。
- 这就是威胁模型中的错配。



SET协议的例子

- SET是用于使用信用卡进行在线购物的协议。
- 它的一个特性是加密信用卡号使得窃听者不能复制它，即使商家也不能看到客户的信用卡号
- 但整个商务系统都建立在商家可以访问客户信用卡号的假设的基础上。
- SET只是在传输过程中保护信息，而大多数被盗取的信用卡号是从商家的数据库里被窃取的。
- SET解决的就是一个错误的问题。



威胁模型是重要的。

- 当开始研发一个密码安全项目时，要坐下来考虑所要面临的风险是什么。
- 错误的风险分析会致使整个项目毫无意义。
- 在任何实际系统中，绝不能忘记对每个参与方的风险分析。



例子：车与车钥匙

- 想要保证汽车免于被盗，最直接的办法是用物理的方式保护汽车，但显然不现实。
- 因此我们使用车钥匙，而汽车则可以直接停放到大街上，保护好车钥匙即可。
- 保护一把车钥匙比保护一辆汽车容易得多。
- **但引入了车钥匙给攻击者带来了一条新的攻击路线**
 - 即攻击者可以直接窃取车钥匙，进而盗窃汽车。

密码不是安全问题的解决方案，而是解决方案的一部分。

- 在许多情况下，密码系统可能使得问题变得更严重，而且甚至根本不清楚采用密码系统是否是一种改进。



另一个例子：

- 一份秘密文件如果进行了加密，那么我们只需要保护好加密密钥。
- 而加密文件本身，就不再是保密的，正如停放在大街上的汽车一样。
- 此时，**由于采用了加密系统，攻击者反而多了两条攻击路径。**
 - **窃取密钥：**一些应用程序会将较长的密钥存储在磁盘上，攻击者使用一定的攻击便可获取。
 - **直接攻破加密系统：**攻击者可以采用暴力破解等方法强行解密公开的秘密文件。最终，整体的安全性降低了。
- 因此，密码系统不是完整的解决方案。它只是部分解决方案，而且它本身带来的问题比它解决的问题更多。



密码系统的实现是极其困难的，即使经验丰富的专家也会设计出一些几年后被攻破的系统。

- 一个重要问题是缺乏测试。
- 没有已知的方法可以测试一个系统是否安全，**我们能够做的最好的办法是公布该系统然后等待其他专家来分析它。**
- 我们注意到后者不是自动的，**有很多已公布的系统自其发布以来甚至没有人看它一眼。即便会议文章和期刊文章也只是受到最基本的评审。**
- 这些评审过程旨在筛选出好的文章和一般的文章，而不是检查其结果的安全性或正确性。
- 有些检查是要做的，但是一般的评审人没有时间对一篇文章做全面的分析。



即使密码系统本身是困难的，但它仍然是一个安全系统中比较容易实现的部分。

- 如同锁一样，密码组件有良好定义的边界和需求。
- 清晰地定义整个安全系统则困难得多，因为它涉及到更多的方面。
- 如果机器中的软件包含了成千的bug并导致安全漏洞，那么安全软件就不可能生效。



- 密码系统带来的问题，我们知道该如何解决。
- 但其他的安全系统包含了一些我们不知道如何解决的问题。
- 密钥管理和密钥存储在任何密码系统中都是至关重要的，**但是大多数计算机都没有一个安全的地方来存储密钥。**
- 当你把用户加入进去之后，我们完全无法干预用户的行为。
- 密钥的泄露方式变得更加多样，问题更难以解决了。

3

重要密码法律



重要密码法律



✓ 3.1 密码法

✓ 3.2 网络安全法

✓ 3.3 关键信息基础设施安全保护条例



中国密码学领域的杰出人物



姚期智院士

清华大学交叉信息研究院院长

- 姚期智院士是世界著名计算机学家，2000年图灵奖得主，是第一位获得图灵奖的亚裔学者。也是中国科学院院士、美国科学院外籍院士等多项国际学术荣誉的获得者。
- 姚教授在多个领域做出了突出贡献，奠定了现代密码学的基础，解决了量子计算、线路复杂性等领域的开放性问题。
- 他是量子计算与通讯的国际先驱之一，为量子通讯协议安全性提供了理论基础。

作为计算机科学领域的领军人物，他不仅推动了学术发展，也为中国信息技术和量子计算的发展做出了重大贡献。



中国密码学领域的杰出人物



王小云院士

清华大学高等研究院教授

- 她因成功破解国际重要密码算法MD5和SHA-1而享誉全球，推动了密码标准的更新。
- 王小云还带领团队设计了我国首个哈希函数标准SM3，该算法广泛应用于金融、交通等重要领域，提升了我国的信息安全技术水平。
- 她不仅促进了国际密码标准的改进，也为我国密码法的发展和信息安全体系建设做出了重要贡献。

王小云的工作彰显了中国在全球密码学领域的影响力，推动了国家安全和技术的自立自强，为我国在信息安全领域的崛起提供了坚实支撑。



中国密码学领域的杰出人物



来学嘉教授

上海交通大学网络空间安全学院教授

- 来学嘉教授设计的IDEA算法，对分组加密研究产生了重大影响，并提出了高阶差分和马尔科夫密码的概念，成为密码算法安全评估的重要工具。
- 来学嘉教授还参与了多个国际安全标准的制定，包括ISO-13888不可抵赖标准和ISO-11770密钥管理标准等。他的研究成果被广泛应用并影响全球密码学界。

作为我国密码科学研究和人才培养的领军人物，来学嘉教授也进一步推动了中国特色网络安全教育和科研的进步。



我国商用密码国际化开展情况





- 密码是国家重要战略资源，密码工作是党和国家的一项特殊重要工作，直接关系到国家安全。
- 密码法的颁布和实施，将有力提升密码工作的科学化、规范化、法制化水平，促进密码事业发展，切实维护国家安全、社会公共利益以及公民、法人和其他组织的合法权益。

科普视频1: <http://baike.baidu.com/l/Dv5i3dHF>



密码的分类和管理

- 保障中央政令军令安全
 - **核心密码**：保护绝密级机密级秘密级信息
 - **普通密码**：保护机密级秘密级信息
- 广泛应用于国民经济发展和生产生活的方方面面
 - **商用密码**：保护不属于国家秘密的信息



核心密码、普通密码

- **核心密码**用于保护国家绝密级、机密级、秘密级信息。
- **普通密码**用于保护国家机密级、秘密级信息。
- 何时使用核心密码，何时使用普通密码，要依据信息使用的主体、秘密信息的性质以及具体的使用场合来确定，在这方面密码法都有明确的规定。

商用密码

- **商用密码**用于保护不属于国家秘密的信息，公民、法人和其他组织都可以依法使用商用密码。



需要应用密码的重要领域网络和信息系统有哪些？

□ 基础信息网络：

- 电信网、广播电视网、互联网。

□ 重要信息系统：

- 能源、教育、公安、测绘地理信息、社保、交通、卫生计生、金融等涉及国计民生和基础信息资源的重要信息系统。

□ 重要工业控制系统：

- 核设施、航空航天、先进制造、石油石化、油气管网、电力系统、交通运输、水利枢纽、城市设施等重要工业控制系统。

□ 面向社会服务的政务信息系统：

- 党政机关和使用财政性资金的事业单位和团体组织使用的面向社会服务的信息系统。



适用范围

- 在中华人民共和国境内建设、运营、维护和使用网络，以及网络安全的监督管理，适用本法。

目标

- 国家保护公民、法人和其他组织依法使用网络的权利，促进网络接入普及，提升网络服务水平，为社会提供安全、便利的网络服务，保障网络信息依法有序自由流动。

《网络安全法》科普视频：<http://baike.baidu.com/l/LXA8wPqO>



网络安全法的意义

- **保障国家网络安全：**明确网络空间主权，维护国家安全和公民权益，推动依法治网。
- **促进信息化发展：**确保网络安全与信息化同步推进，保障国家经济和社会稳定。
- **明确各方责任：**规定各方责任，强化网络产品和服务提供者的安全义务，推动规范管理。
- **加强关键信息基础设施保护：**重点保护关键信息基础设施，确保国家安全和民生利益。
- **推动共同治理：**鼓励政府、企业、网络运营者和公民共同参与网络安全治理。

《网络安全法》为我国网络空间的法治建设和安全治理提供了坚实的法律基础，确保网络空间健康、有序发展，是科技强国的战略支撑。



网络安全法的六大方面

□ 基本原则

- 网络空间主权原则

- 网络安全与信息化发展并重原则

- 共同治理原则

- 提出制定网络安全战略，明确网络空间治理目标，提高了我国网络安全政策的透明度

- 进一步明确了政府各部门的职责权限，完善了网络安全监管体制

- 《网络安全法》强化了网络运行安全，重点保护关键信息基础设施

- 完善了网络安全义务和责任，加大了违法惩处力度

- 将监测预警与应急处置措施制度化、法制化



案例：非法侵入他人电脑——造成危害可治安拘留或刑拘

- 2009年，宁夏永宁县政府网站受到黑客攻击，首页变成了恐怖分子的照片。经警方调查发现，一位黑客早些年到永宁县政府的网站里“溜达”了一圈后，随手放置了一个后门程序。
- 不久，永宁县政府网站存在的漏洞被恐怖分子发现，便利用这名黑客先前放置的后门程序，“黑”了永宁县政府的网站。
- 根据《治安管理处罚法》第29条规定，违反国家规定，侵入计算机信息系统，造成危害的，处5日以下拘留；情节较重的，处5日以上10日以下拘留。



个人信息泄露原因与对策

□ 个人信息泄露原因

- 在市场需求和利益驱动下，一些不法分子打起了获取、兜售公民个人信息的歪主意。
- 一些网络、电话销售、保险、贷款等公司的从业人员，把自己掌握的“个人信息资源”，卖给了不法分子。
- 个人在浏览、登录网站，点击中奖信息、随便安装来路不明的软件等，不慎泄露了自己的信息。

□ 对策

- 明确个人信息保护的原则和要求，落实工作责任，加强监管保护，明确滥用他人个人信息的行政处罚制度和责任。



《关键信息基础设施安全保护条例》是根据《中华人民共和国网络安全法》制定的条例，旨在建立专门保护制度，明确各方责任，提出保障促进措施，保障关键信息基础设施安全及维护网络安全，

2021年4月27日，经国务院第133次常务会议通过。

2021年7月30日，国务院总理李克强签署中华人民共和国国务院令 第745号，公布《关键信息基础设施安全保护条例》，自2021年9月1日起施行。

《关键信息基础设施安全保护条例》科普视频：<http://baike.baidu.com/l/IVsO0Ldz>



《关键信息基础设施安全保护条例》对我国网络安全和国家安全具有重要意义：

- **增强国家安全意识：** 强调关键信息基础设施的保护，提升全社会对信息安全的关注，激发公民责任感。
- **推动社会治理创新：** 通过多部门协同管理，推动国家治理体系和法治建设。
- **落实法治建设与责任：** 明确运营者主体责任，促进全社会共同维护网络安全。
- **培养网络安全人才：** 加强网络安全人才培养，提升国家信息安全防护能力。
- 《条例》的实施为我国网络安全提供了法律保障，推动社会安全与信息化进程，体现了科技强国建设的战略部署。



1. 在密码工程中，为什么仅依赖密码本身无法保证系统的安全？
2. 你认为密码系统中最重要的安全措施是什么？为什么？



1. 为“如何伪装成某人发送电子邮件”创建攻击树，这里攻击者的目标是让电子邮件的收件人相信它收到的邮件是发自某人的（例如Bob），而Bob实际上没有发送过这封邮件。
2. 描述一个你熟悉的攻击案例，分析该系统的安全威胁脆弱点，并分析该攻击案例中，攻击者是否利用了系统最脆弱的环节发起攻击？

谢谢大家
